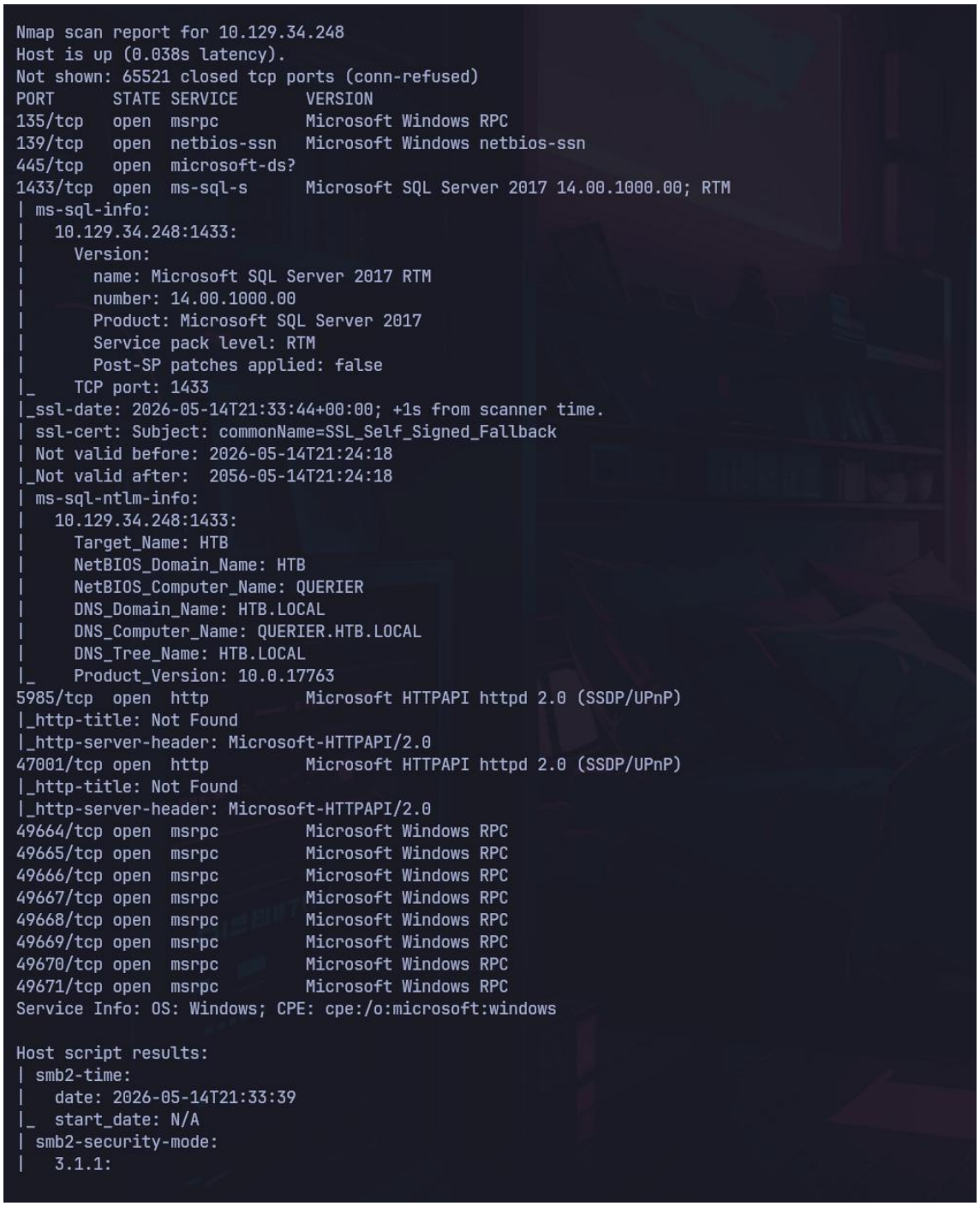
Enumeración

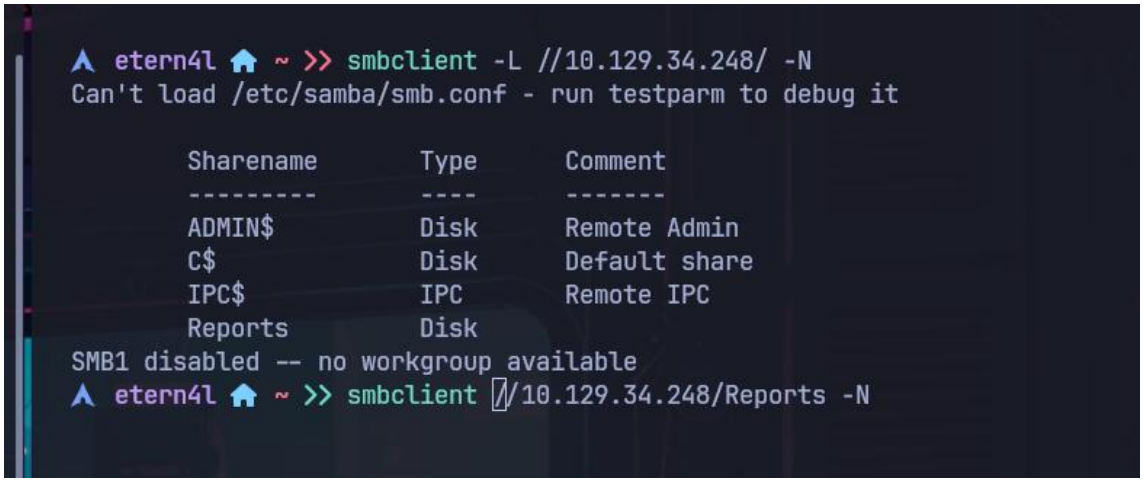
Comenzamos con la enumeración de puertos y servicios



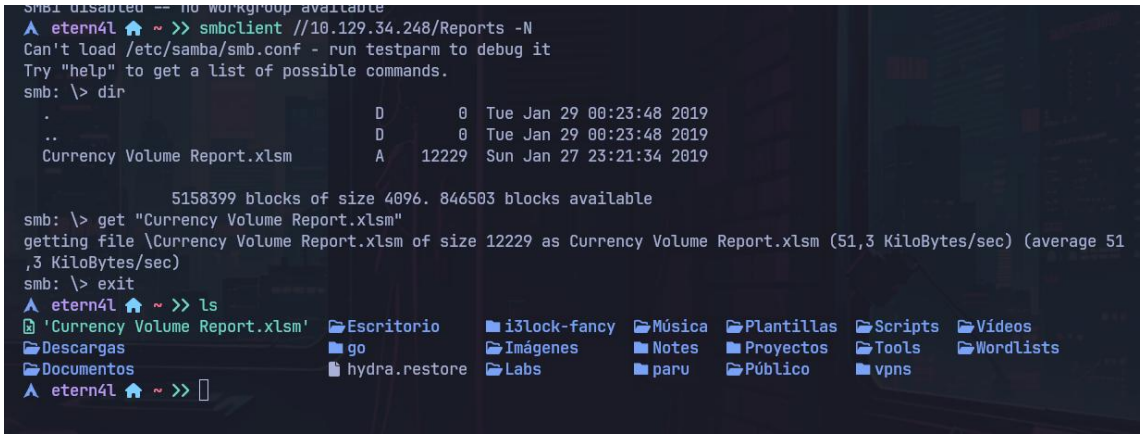
```
Nmap scan report for 10.129.34.248
Host is up (0.038s latency).
Not shown: 65521 closed tcp ports (conn-refused)
PORT      STATE SERVICE       VERSION
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s      Microsoft SQL Server 2017 14.00.1000.00; RTM
| ms-sql-info:
|   10.129.34.248:1433:
|     Version:
|       name: Microsoft SQL Server 2017 RTM
|       number: 14.00.1000.00
|       Product: Microsoft SQL Server 2017
|       Service pack level: RTM
|       Post-SP patches applied: false
|_    TCP port: 1433
|_ssl-date: 2026-05-14T21:33:44+00:00; +1s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-05-14T21:24:18
|_Not valid after:  2056-05-14T21:24:18
| ms-sql-ntlm-info:
|   10.129.34.248:1433:
|     Target_Name: HTB
|     NetBIOS_Domain_Name: HTB
|     NetBIOS_Computer_Name: QUERIER
|     DNS_Domain_Name: HTB.LOCAL
|     DNS_Computer_Name: QUERIER.HTB.LOCAL
|     DNS_Tree_Name: HTB.LOCAL
|_    Product_Version: 10.0.17763
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49666/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49668/tcp open  msrpc         Microsoft Windows RPC
49669/tcp open  msrpc         Microsoft Windows RPC
49670/tcp open  msrpc         Microsoft Windows RPC
49671/tcp open  msrpc         Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-05-14T21:33:39
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
```

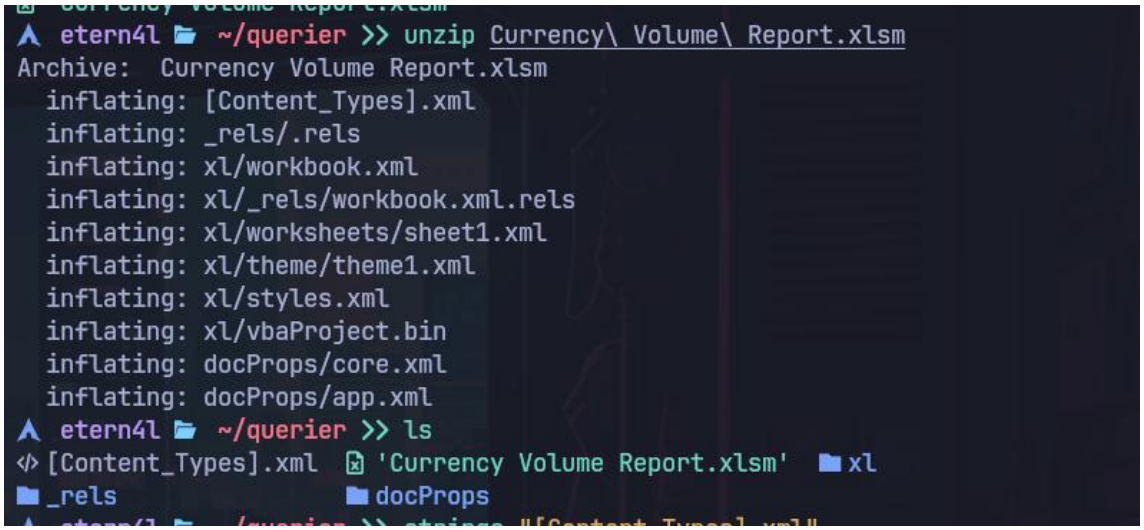
Empezamos enumerando por SMB y nos encontramos un recurso en el cual tenemos acceso sin necesidad de credenciales



Encontramos un documento Excel que nos descargamos



Procedemos a descomprimirlo

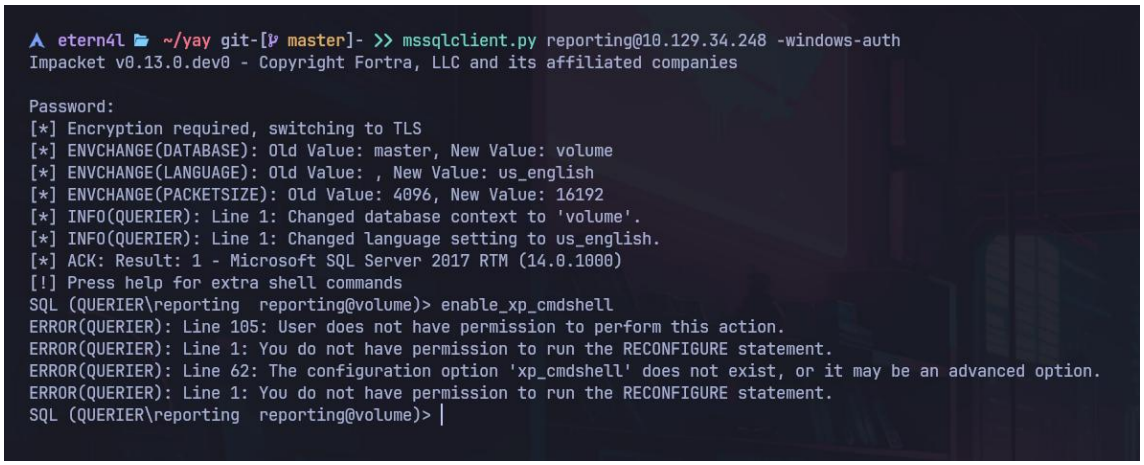


Después de estar enumerando el contenido extraído con “strings” encontramos una contraseña en el binario “vbaProject.bin”

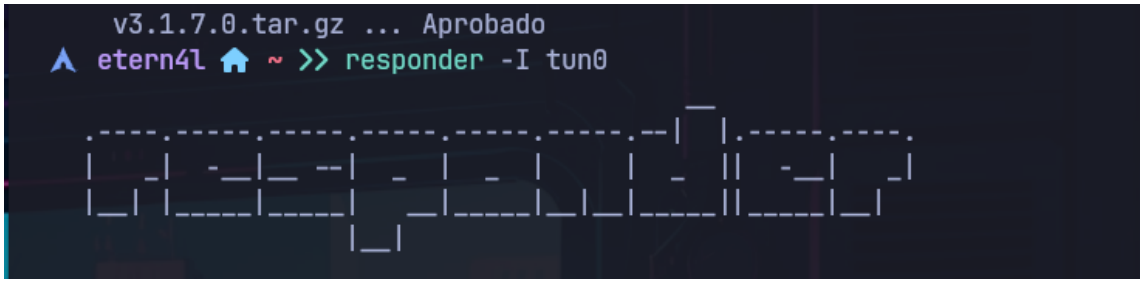


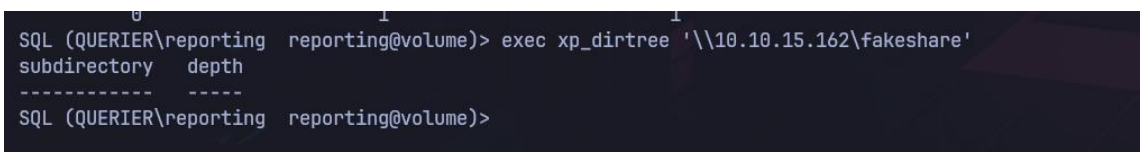
Enumerando los archivos Excel encontramos el usuario “reporting” el cual probamos a conectarnos a “mssql” y conseguimos acceder.

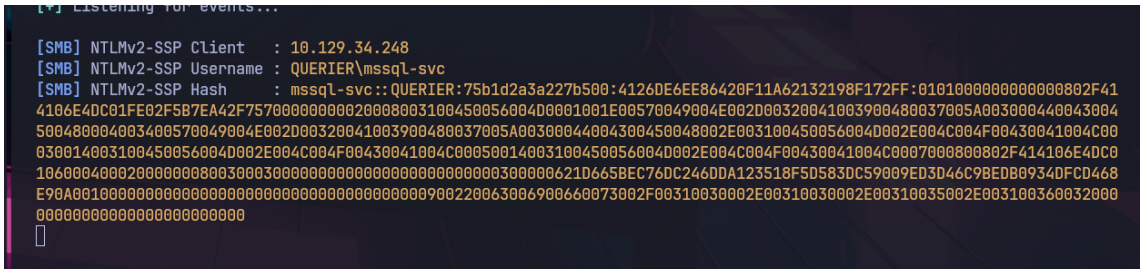
Al intentar activar una Shell vemos que no tenemos permiso



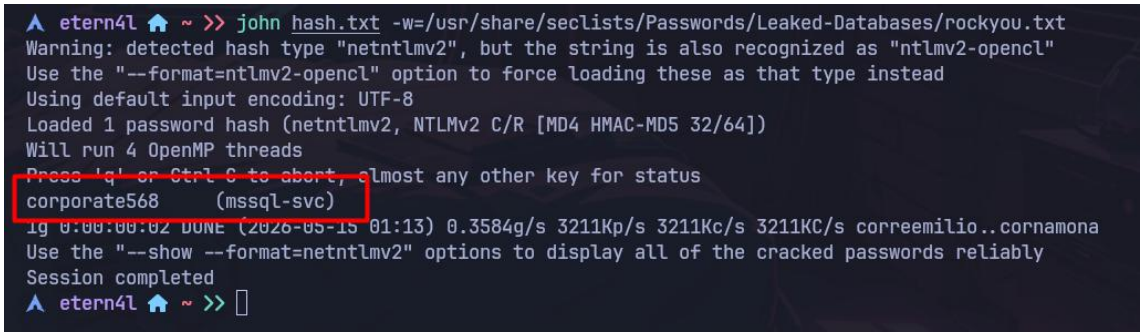
Procedemos a levantar Responder, una herramienta que simula servicios de red legítimos para capturar autenticaciones NTLM. Mediante xp_dirtree, forzaremos al servidor MSSQL a conectarse a nuestro recurso SMB, provocando el envío automático del hash NetNTLMv2.



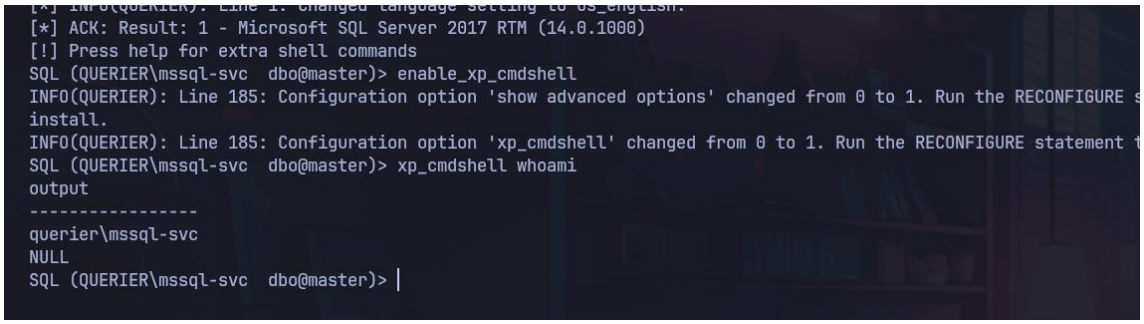




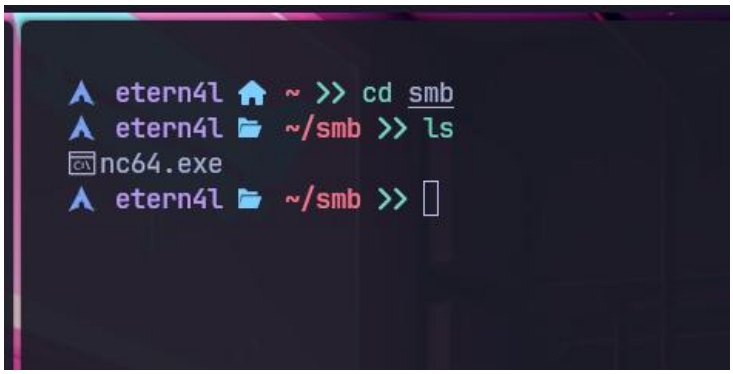
Procedemos a crackear el hash NetNTLMv2 capturado utilizando John The Ripper, obteniendo las credenciales de la cuenta mssql-svc.



Nos autenticamos nuevamente en MSSQL utilizando el usuario mssql-svc. Debido a que esta cuenta pertenece al rol sysadmin, ahora sí es posible habilitar xp_cmdshell y ejecutar comandos a nivel de sistema operativo.



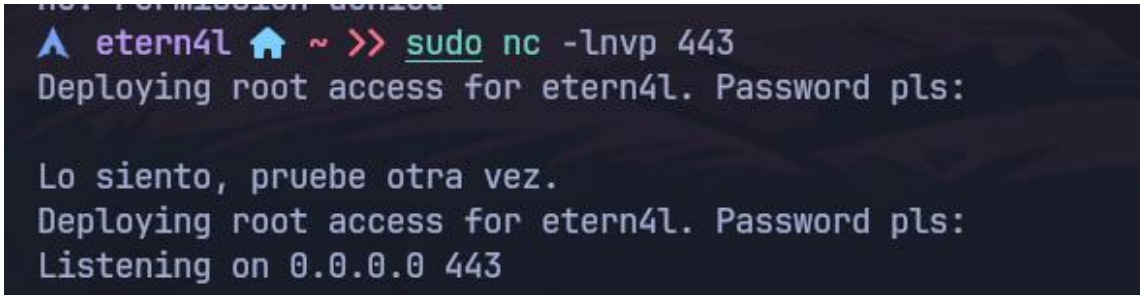
Una vez confirmada la ejecución de comandos procedemos a descargarnos “nc64.exe” que es netcat para Windows y nos servirá para obtener una Reverse-Shell



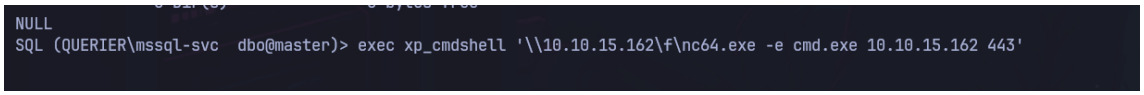
Levantamos un servidor smb para compartir la carpeta actual donde tenemos “nc64.exe”

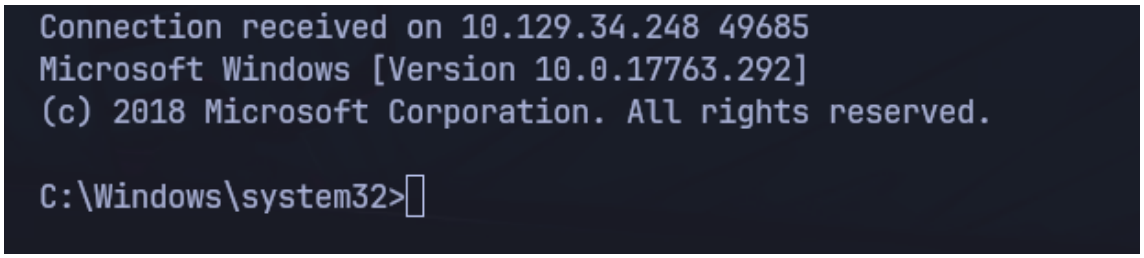


Nos ponemos en otra terminal a la escucha con netcat



Mediante xp_cmdshell, ejecutamos nc64.exe desde nuestro recurso SMB compartido. El binario establece una reverse shell hacia nuestro listener en el puerto 443.





Obtenemos la primera Flag.



Observamos que el usuario mssql-svc posee el privilegio SeImpersonatePrivilege, el cual puede ser abusado mediante técnicas Potato/PrintSpoofer para impersonar tokens privilegiados y obtener ejecución como NT AUTHORITY\SYSTEM.

